

SONARQUBE CHEAT SHEET

Main concepts & metrics.



SonarQube version: **6.3+** - Date: **February 2018**

MAIN CONCEPTS

Quality Gates : Set of boolean conditions based on measure thresholds **against which projects are measured during a period.**

Blocker Issues equals 0
Code Coverage is greater than 80%

Rules: rules are executed on source to generate issues. Three basic types of rules: **Reliability, Maintainability and Security**

Rule definition:

- Language
- Type: bug, vulnerability, code smell
- Tag
- Repository
- Status: beta, deprecated, ready

Example:

".equals()" should not be used to test the values of "Atomic" classes
Language: Java
Type: bug
Tag: multi-threading
Repository: N/A
Status: ready

Quality profiles : Collections of rules to apply during an analysis. Each language has a default profile

Metric : A type of measurement. Examples: number of lines of code, number of duplicated blocks, complexity etc.

Reliability : code that can produce operational risks or unexpected behavior at runtime. Must of time it's the consequence of lack of compliance with best practice

MAIN CONCEPTS

Leak period : period (generally last release) in which newly added code is analysed against specified criteria.

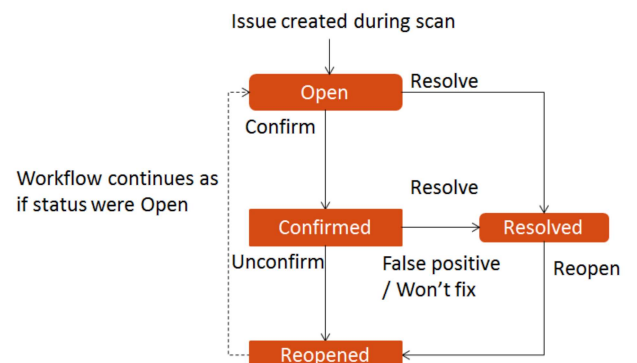
Maintainability : modularity, understandability, changeability, testability and reusability of a module.

Issue : SonarQube raise an issue every time a piece of code breaks a code rule. Issue severities:

- **BLOCKER**: memory leak, not closing a socket... The code **MUST** be fixed immediately.
- **CRITICAL**: SQL Injection, NullPointerException: The code **MUST** be reviewed immediately.
- **MAJOR**: duplicated blocks, unused parameters
- **MINOR**: naming convention, lines too long,...
- **INFO**

ISSUE LIFE CYCLE

Except Opened state, the others statuses can be set manually. It **requires administer issues permission** on the project



MAIN METRICS

- **Quality Gate Status** : State of the quality gate associated to the project. Possible values: ERROR, WARN, OK. It changes after each scan.
- **Reliability** : Number of bugs, number of new bugs, etc... Reliability rating: A = 0 bug, B = at least **1 Minor** bug, C = at least 1 **Major** bug, D = at least **1 critical** bug, E = at least **1 Blocker** bug
- **Security** : Number of vulnerabilities, number of new vulnerabilities, etc... Reliability rating same as Reliability rating
- **Complexity** Cyclomatic complexity is used up to version 6.3. It's measured on choices and branches i.e. numbers of if, else, while, switch/case It is recommended to have at least a cyclomatic complexity of 12 in a method. Each method add 1 to the complexity.

```
``` String getMonth (int monthNumber) { //+1 switch
(monthNumber) { case 1: //+1 return "January"; case 2:
//+1 return "February"; default: return "Error"; } } ```
```

- **Metric** : Number of classes, files, lines, lines of code, methods, projects, statements ....
- **Duplications** : duplicated blocks, files, lines
- **Maintainability** : Number of code smells, technical debt i.e effort to fix all maintainability issues.
- **Tests** : Condition coverage, line coverage, etc...

Condition coverage = (conditions evaluated to true at least once + conditions evaluated to false at least once) / (2\* total number of conditions)

```
boolean a = false;
boolean b = true;
boolean c = false;
```

```
if(a && (b || c)){ ...}
```

Condition coverage = (2 + 1) / (2\*3) = 0.5

## ANALYSIS PARAMETERS

df = default value

Parameter	Description
sonar.host.url	Server URL, df = <a href="http://SONAR_SERVER_IP:9000">http://SONAR_SERVER_IP:9000</a>
sonar.project.key	The project key that is unique for each project. When using maven df = <groupId>:<artifactId>
sonar.login	The login of a SonarQube user with Execute Analysis permission.
sonar.password	The password that goes with sonar.login.
sonar.language	Set the language of the source code to analyse. If not set multi-language analysis will be triggered

## TOOLS

- **Sonarlint:**
  - Allows to fix issues on the fly and when code changes
  - Available as a plugin for IDE
  - [sonarlint web site](https://www.sonarlint.org/)
- **EclEmma:**
  - Allows to check coverage code by unit tests. It's based on JaCoCo library
  - Available as a plugin for Eclipse IDE
  - [EclEmma web site](http://www.eclemma.org/)
- **Jscpd:**
  - Allows to detect copy/paste code
  - [Jscpd web site](https://github.com/kucherenko/jscpd)